

All 12 factors are covered. Here is the assessment.

AI Application Risk Assessment (Internal Pilot)

1. Intake

- **Owner:** Jamie Jaworski
- **Business Unit:** Cybersecurity
- **Use Case:** A conversational assistant that conducts structured security risk assessments of proposed agentic AI applications, guiding the user through a fixed 12-factor interview and producing a weighted risk report for human review.

2. Executive Summary

- **Overall Risk Level:** Low
- **Overall Weighted Score:** 2.34 (32.7 ÷ 14.0)
- **Top Risk Drivers (highest weighted contribution):**
 1. **Guardrails & Monitoring Maturity (6.0)** — no guardrails, input filtering, or usage monitoring exist in the current version.
 2. **Data Sensitivity & Privacy (4.2)** — sensitive data is not *required*, but nothing technically prevents a user from pasting NPPI, credentials, or control-gap detail into the prompt.
 3. **Reliability & Failure Modes (3.3)** — no independent validation that scoring arithmetic is correct or that all 12 factors were actually evaluated.
 4. **Transparency & Explainability (3.2)** — sessions are ephemeral; a completed assessment cannot be reconstructed or audited after the fact.
 5. **Task Complexity & Ambiguity (3.0)** — scoring is inherently judgment-based, and open-ended follow-ups allow the conversation to drift off the fixed structure.

The risk profile is meaningfully suppressed by strong structural controls: no system connectivity, no tools, no autonomous action, mandatory human review, and secondary AI Committee review. Residual risk concentrates almost entirely in **operational immaturity** — the absence of guardrails, logging, and output validation — rather than in the application's inherent design.

3. 12-Factor Risk Evaluation

#	Factor	Weight	Score	Weighted	Rationale
1	Autonomy & Human Oversight	1.5	1	1.50	All output is human-reviewed and the app takes no autonomous actions of any kind.
2	Scope of Access & Permissions	1.4	1	1.40	No connectivity to external systems or data; no read or write permissions anywhere.
3	Reversibility of Actions	1.3	2	2.60	Outputs are drafts subject to AI Committee review, though a flawed rating could anchor reviewer judgment before correction.

#	Factor	Weight	Score	Weighted	Rationale
4	Task Complexity & Ambiguity	1.0	3	3.00	The 12-step structure is fixed, but risk scoring is subjective and open-ended follow-ups permit conversational drift.
5	Tool & Chain-of-Action Risk	1.1	1	1.10	Purely conversational text-in/text-out with no tools, file ingestion, or chained actions.
6	Data Sensitivity & Privacy	1.4	3	4.20	Sensitive data is never required, but no technical control prevents entry of NPPI or internal control-gap detail into prompts.
7	Transparency & Explainability	0.8	4	3.20	Sessions disappear on close, so assessments and their reasoning cannot currently be reconstructed or audited.
8	Reliability & Failure Modes	1.1	3	3.30	The app re-prompts on incomplete input, but nothing validates score arithmetic, weight application, or factor coverage.
9	Scale & Blast Radius	1.3	2	2.60	Currently a single user, expanding to one team — limited but growing exposure.
10	Guardrails & Monitoring Maturity	1.2	5	6.00	No guardrails, prompt-injection protection, DLP, usage logging, or alerting exist today.
11	Vendor & Model Dependency	0.8	2	1.60	Runs on enterprise Copilot Studio and is model-agnostic, but model swaps can silently shift scoring behavior.
12	Regulatory & Compliance Context	1.1	2	2.20	Strictly internal advisory today, though the subject matter is AI governance and could later become examiner-visible.
Totals		14.0		32.70	Overall: $32.70 \div 14.0 = 2.34$ — Low

4. Recommended Mitigations

Driver 1 — Guardrails & Monitoring (Score 5, highest contributor)

- Add a **system-prompt protection layer** resistant to override, extraction, and role-reassignment attempts; test with adversarial prompts before team rollout.
- Implement **input filtering / DLP pattern matching** for common sensitive-data formats (account-number patterns, SSN patterns, API keys, credential strings) with an inline block-and-warn.
- Enable **Copilot Studio conversation and usage analytics** at minimum, even before full transcript retention is built.
- Add a persistent **on-screen data-handling notice** at session start reinforcing the "no PII/NPPI/credentials" rule.

Driver 2 — Data Sensitivity & Privacy (Score 3)

- Confirm and **document the Copilot Studio tenant's data-handling terms**, including retention period and no-training-on-prompts commitments, for each model backend used.
- Define an explicit **data classification ceiling** for the app (e.g., "Internal — no Confidential/Restricted") and state it in user guidance.
- Establish a **spill-response procedure**: if sensitive data is entered, who is notified and how the session data is purged.

Driver 3 — Reliability & Failure Modes (Score 3)

- Add a **deterministic scoring check** — recompute weighted totals outside the model (or via a validation step) rather than relying on LLM arithmetic.
- Enforce a **completeness gate**: the report cannot be produced unless all 12 factors have a recorded score and rationale.
- Run a **consistency benchmark**: submit 3–5 identical reference use cases across sessions and models, and measure score variance. Investigate any factor varying by more than ± 1 .

Driver 4 — Transparency & Explainability (Score 4)

- Prioritize the planned **session resumption and output reconstruction** feature; treat it as a prerequisite for any use beyond testing.
- Until then, require users to **export and retain the full report** to a controlled repository, recording model used, date, and app version.
- Add **model and version stamping** to every generated report so results are traceable to the configuration that produced them.

Driver 5 — Task Complexity & Ambiguity (Score 3)

- Publish **anchored scoring definitions** (concrete descriptors for what a 1 vs. 3 vs. 5 means on each factor) to reduce subjective drift.
- Constrain follow-up questions to a bounded set tied to specific factors.
- Require the AI Committee to treat scores as **advisory input, not a determination** — document this explicitly in the committee charter.

Cross-cutting — Vendor & Model Dependency

- Maintain an **approved-model list** for the app and require re-benchmarking whenever the backing model changes.

5. Monitoring & Operational Considerations

What should be logged

- Full conversation transcript, timestamped, tied to authenticated user identity
- All 12 factor scores, weights applied, computed weighted total, and final risk level
- Model and version used, plus app/system-prompt version
- Any DLP or guardrail trigger events (attempted sensitive-data entry, prompt-injection attempts)
- Final report export events and destination

What should be monitored or alerted

- Alerts on DLP pattern matches and system-prompt override attempts

- Anomalous usage volume or off-hours use once rolled out to the team
- Score distribution drift — a sudden shift toward low ratings may indicate model change or prompt degradation
- Incomplete or abandoned assessments that were nonetheless exported
- Divergence between app-generated ratings and final AI Committee determinations (a direct quality signal)

Expected ownership and review cadence

- **Accountable owner:** Jamie Jaworski (Cybersecurity)
- **Weekly during pilot:** owner reviews all assessments generated, logging any factual errors, arithmetic errors, or skipped factors
- **Monthly:** review app-vs-committee rating divergence and guardrail trigger events
- **Before each expansion of the user base:** re-run this assessment, since Scale & Blast Radius and Guardrails scores will both change
- **On any model change:** re-benchmark against reference use cases before resuming production use

6. Disposition Guidance (Non-Approval)

Suitable for controlled pilot with guardrails.

The application's inherent risk is genuinely low — it has no system access, no tools, no autonomy, and two layers of human review. That structural containment is the dominant reason the overall score lands at **2.34 (Low)**.

However, **expansion beyond the Cybersecurity test group requires additional controls before it should proceed**, specifically: (a) session retention and output reconstruction, (b) basic input guardrails and DLP, and (c) deterministic validation of scoring arithmetic and factor completeness. Absent transcript retention, the organization currently cannot demonstrate how any given risk rating was reached — an acceptable gap for a single-user pilot, but not for a tool whose output informs AI Committee decisions at scale.

Note also a **conflict-of-interest consideration**: this assessment was produced by the tool being assessed, for its own owner. Recommend an independent reviewer outside Cybersecurity validate this assessment before it is presented to the AI Committee.

Assumptions documented (scored conservatively where information was unavailable):

- No formal user training or acceptable-use documentation currently exists for the app.
- Copilot Studio tenant data-retention terms were not confirmed during intake and are assumed to be standard enterprise terms, not verified.
- No adversarial/prompt-injection testing has been performed to date.
- Planned future capabilities (session resumption, guardrails) were **not** credited, per current-state-only scoring.

If any of these assumptions are incorrect, let me know and I'll re-score the affected factors.